

Module 4: Web Application Security



Topic 2: HTML



What is HTML?

HTML is HyperText Markup Language. It is not a programming language. It's used for creating web pages or documents displayed by the web browser. It can be used with Cascading Style Sheet (CSS) and Javascript to provide good-looking interactive web pages for users.

Why learn HTML basics?

HTML basics are needed in web penetration testing because they can be used in some vulnerability testing.

HTML Forms: GET

```
<HTML>
  <FORM METHOD="GET" ACTION="/cgi-bin/login.asp">
    Username: <INPUT TYPE="TEXT" NAME="UserId" VALUE=""><BR>
    Password: <INPUT TYPE="PASSWORD" NAME="Passwd" VALUE=""><BR>
               <INPUT TYPE="HIDDEN" NAME="SessionId" VALUE="123142iousakdnj234091231234">
               <INPUT TYPE="SUBMIT" NAME="SUBMIT" VALUE="Click to login">
  </FORM>
</HTML>
```

Username:

Password:

```
GET /cgi-bin/login.asp?UserId=jsmith&Passwd=Demo1234&SessionId=123142iousakdnj23
4091231234&SUBMIT=Click+to+login HTTP/1.1
Accept: image/gif, image/x-xbitmap, image/jpeg, image/pjpeg, application/x-shock
wave-flash, application/vnd.ms-excel, application/vnd.ms-powerpoint, application
/msword, */*
Accept-Language: en-us
Accept-Encoding: gzip, deflate
User-Agent: Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1; SV1; .NET CLR 2.0
.50727; .NET CLR 1.1.4322)
Host: localhost:8888
Connection: Keep-Alive
```

GET

HTML Forms: POST

```
<HTML>
  <FORM METHOD="GET" ACTION="/cgi-bin/login.asp">
    Username: <INPUT TYPE="TEXT" NAME="UserId" VALUE=""><BR>
    Password: <INPUT TYPE="PASSWORD" NAME="Passwd" VALUE=""><BR>
               <INPUT TYPE="HIDDEN" NAME="SessionId" VALUE="123142iousakdnj234091231234">
               <INPUT TYPE="SUBMIT" NAME="SUBMIT" VALUE="Click to login">
  </FORM>
</HTML>
```

Username:

Password:

```
POST /cgi-bin/login.asp HTTP/1.1
Accept: image/gif, image/x-xbitmap, image/jpeg, image/pjpeg, application/x-shock
wave-flash, application/vnd.ms-excel, application/vnd.ms-powerpoint, application
/msword, */*
Accept-Language: en-us
Content-Type: application/x-www-form-urlencoded
Accept-Encoding: gzip, deflate
User-Agent: Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1; SV1; .NET CLR 2.0
.50727; .NET CLR 1.1.4322)
Host: localhost:8888
Content-Length: 89
Connection: Keep-Alive
Cache-Control: no-cache
```

```
UserId=jsmith&Passwd=Demo1234&SessionId=123142iousakdnj234091231234&SUBMIT=Click
+to+login
```

POST

HTML Example

Now, let's see a simple example for creating a web page:

```
<> index.html >  html
1  <!DOCTYPE html>
2  <html>
3  <head>
4  <title>Page Title</title>
5  </head>
6  <body>
7  <h1> Heading example</h1>
8  </body>
9  </html>
```

Each HTML page starts and ends with HTML tag. It contains all HTML elements.

HTML and XSS

As the Cross-Site Scripting (XSS) (used to steal user cookies), in which you can create your own page with the malicious content and submit it in the target website input field where that attack would be triggered.

Here is an example of one of the HTML testing content.

```
<body>  
  <video><source onerror="alert(1)">  
</body>
```

It will trigger the handler onerror and this handler will make alert(1) which will make a pop-up on the target page with value 1.